CyBOK

Penetration testing Research and State of the Art

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

This lecture

- This lecture will focus on current challenges and what the research has to offer
- With a continuously developing area, new things are happening all the time
- The idea here is to discuss some of the current trends related to pentesting

Litterature note

- The purpose of this lecture is to bring attention to some RnD areas

- The lecture is primarily built on the following publications:
  - Hatfield, J. M. (2019). Virtuous human hacking: The ethics of social engineering in penetration-testing. *computers & security*, *83*, 354-366.
  - Al-Ahmad, A. S., Kahtan, H., Hujainah, F., & Jalab, H. A. (2019). Systematic literature review on penetration testing for mobile cloud computing applications. *IEEE Access*, *7*, 173524-173540.
  - Valea, O., & Oprişa, C. (2020, September). Towards pentesting automation using the metasploit framework. In *2020 IEEE 16th International Conference on Intelligent Computer Communication and Processing (ICCP)* (pp. 171-178). IEEE.

Litterature note

- The lecture is primarily built on the following publications (cont):
  - Heiding, F., Süren, E., Olegård, J., & Lagerström, R. (2023). Penetration testing of connected households. *Computers & Security*, *126*, 103067.
  - Chowdhary, A., Huang, D., Mahendran, J. S., Romo, D., Deng, Y., & Sabur, A. (2020, December). Autonomous security analysis and penetration testing. In *2020 16th International Conference on Mobility, Sensing and Networking (MSN)* (pp. 508-515). IEEE.
  - Formosa, P., Wilson, M., & Richards, D. (2021). A principlist framework for cybersecurity ethics. *Computers & Security*, *109*, 102382.

Agenda

- Ethics with a deep-dive in social engineering
- Automation
- Mobile Cloud pen-testing
- Connected households

Ethics

- Cybersecurity impact systems which are important for
  - Leaisure
  - Finance
  - Work
  - Well-beeing
  - …
- Those systems house sensitive as well as personal identifiable data
- Therfore, cybersecurity is of ethical significance

Ethics

- Some definitions from the Merriam-Webster dictionary
  - the principles of conduct governing an individual or a group
  - a set of moral issues or aspects (such as rightness)
  - the discipline dealing with what is good and bad and with moral duty and obligation

- In essence, guiding principles on right and wrong in different situations

Ethics – why in cybersecurity

CyBOK

- In cybersecurity, we often face situations without a given answer
  - When do you disclose an identified vulnerability?
  - Should pen-testing be taught?
  - What do you do if you uncovered a crime during a pen test?
  - Can be compromise privacy in the name of security?
  - What methods can you use during a pen-test?

- Ethics can guide on such matters

Ethics – why in cybersecurity

CyBOK

- In cybersecurity, we often face situations without a given answer
  - When do you disclose an identified vulnerability?
  - Should pen-testing be taught?
  - What do you do if you uncovered a crime during a pen test?
  - Can be compromise privacy in the name of security?
  - What methods can you use during a pen-test?

- Ethics can guide on such matters

Ethics – why in cybersecurity

CyBOK

- There are several ethical frameworks proposed for cybersecurity
- They are often *principlist* frameworks
  - Compriced of ethical principles
  - Principles can have different weight in different contexts
- Lets have a look at the principles as presented by Formosa et al (2021)

Ethics – Principles

CyBOK

- Beneficence
  - Cybersecurity should be to the benefit of humans
- Non-Maleficence
  - Cybersecurity should not be used to cause harm, on the contrary it should be used to aviod harm
- Autonomy
  - Cybersecurity practises should respect human autnonomy
  - Humans should be able to make decisions about what technology they use and how, including how and what technologies that impact their lives

Ethics – Principles

CyBOK

- Justice
  - Cybersecurity should promote equality, justice, and fairness
  - And not support discrimination or prevent equal access

- Explicability
  - Cybersecurity should be used in ways that are transparent and comprehensible
  - It should be clear who is responsible for its use

REFLECT!

- Use one minute to write down one-liners that reflect cybersecurity practices that have inherent dilemmas.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Ethics – in pentesting

CyBOK

- Pentesting have many inherent ethical dilemmas
  - Can we pentest users?
  - Can we pentest software without the creator’s knowledge?
  - What do we do with excess information?
    - Hamrful to some individual
    - Harmful to a company
    - Hamrful to our company
    - Showing crime by
      - An individual
      - Our contractor

Ethics – in pentesting

CyBOK

- For a pentest to be ethical
  - A contract outlining the scope of the pentest is needed
  - It must also show that the test is indeed authorized

- Ethics very much guides responsible disclosure
  - Oweber of vulnerable software must be given a chance to fix
  - But vulnerabilities must also be publicly disclosed to enable users to protect themselves

Ethics – in Social Engineering

- Social engineering involves all actions where you attempt to talk a target into giving up sensitive information or perform specific actions
- A common hacking technique and, therefore, not uncommon to see as part of a pentest
- Tricking a person is of course not without ethical challenges

Ethics – in Social Engineering

CyBOK

- Social enginnering can include
  - Phishing, vishing, and all the other –ings
  - Attmepting to gain unathorized physical access
  - Attempting to make user take sertain actions over the phone
- In essense, it is about exploiting user behaviour
- And typically without the users knowledge

Ethics – in Social Engineering

- How does that align with our ethical principles
  - Beneficence
  - Non-Maleficence
  - Autonomy
  - Justice
  - Explicability

- The answer depends on perspective
  - The company
  - The individual

Ethics – in Social Engineering

- In practice, we are faced with a tradeoff
- Many argue that the goal can motivate the means
- Minimize harm and maximize benefit
- Not all lines should be crossed

Automation

- Pentesting can be quite complex and time-consuming
- Requires both personnel and money
- To enable more organizations to use pen-testing, and to manage the demand in bigger organizations automation offers a possible solution

Automation

CyBOK

- Automating pen-testing processes can have many benefits
  - Less experiences pen-testers can use automated tests
  - Pen-testers can work on more systems fasted
  - More organizations can benefit from pen-testing because it can be cheaper
- The ever-changing nature of systems is a challenge
- It is also hard to automate the inherent “problem-solving” nature of pen-testing

Automation – semi automation

CyBOK

- Partly automating the pen-testing process can save time while the skills of the pen-tester can be used for what cant be automated.

- Chowdhary et al (2020) propose a method for automating the analysis steps
  - Attack plans are created based on network information
  - Tested for known vulnerabilities

Automation – semi automation

CyBOK

- Vela and Oprisa (2020) suggest a method capable of
  - Doing port scanning and enumeration
  - Search for vulnerabilities
  - Select exploits
  - Run attacks from Metasploit

- In a test, the method managed to exploit 7 out of 148
  - Main obstacle is that machines need to be exploitable by Metasploit (only 10 were)
  - Then only “easy exploitable” machines can be exploited
  - Still, automation of “simple tasks” was successful

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Mobile Cloud Computing

CyBOK

- Mobile Cloud Computing (MCC) includes mobile and cloud services accessed via the Internet
- Typically, MCC models involve using the coloud to run tasks via mobile deveices
- The general idea is to enhance the compute available to mobile device users but that comes with increased complexity

MCC and cybersecurity

CyBOK

- By integrating mobile technologies and cloud technologies, MCC are susceptible to both groups of security problems. With possible added problems due to the interface between the technologies

- Al-Ahmad et al. (2019) argue that the complexity of MCC solutions makes pen-testing a great security tool for them.

Connected households

- Houses now include a lot of connected devices
  - Lamps and sockets
  - Car chargers
  - Fridges
  - Aquarium pumps
  - Alarms
  - ….

- This pose several security risks
  - Managed by home users
  - Low compute devices
  - Often not really developed with a lot of security in mind

Connected households

- Heiding et al. (2022) performed pen tests agains 22 different devieces in five categories
  - Door locks
  - Cameras
  - Garage stuff
  - Appliances
  - Misc

- Found 17 vulnerabilities in total

Connected households

- Houses now include a lot of connected devices
  - Lamps and sockets
  - Car chargers
  - Fridges
  - Aquarium pumps
  - Alarms
  - ….

- This pose several security risks
  - Managed by home users
  - Low compute devices
  - Often not really developed with a lot of security in mind

Connected households

- 17 vulnerabilities we found
  - 13 related to smart cars and garages
  - 2 related to smart door locks
  - 2 related to smart appliances
- Another 52 weaknesses were found
- What do we want to use smart devices for?

REFLECT!

- Use one minute to write down one-liners that reflect what you learned so far.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Thank you for today!